

Post-Quantum Cryptography-Secured Federated Learning for Healthcare: A Three-Layer Privacy Framework with Byzantine Robustness and Differential Privacy

Mohamed Waseem

Department of Computer Science,
Sathyabama Institute of Science and Technology, Chennai, India
waseem177@gmail.com

Mohammed Fawaz

Department of Computer Science,
Sathyabama Institute of Science and Technology, Chennai, India
fawaznx97@gmail.com

Abstract—Federated learning (FL) enables multiple hospitals to collaboratively train machine learning models without sharing raw patient data. However, existing FL deployments rely on classical cryptographic schemes—RSA and HMAC—that are vulnerable to harvest-now-decrypt-later attacks from quantum-capable adversaries. We present PQC-FL-Health, a three-layer security framework for federated healthcare analytics that replaces classical primitives with NIST-standardised post-quantum cryptography (PQC): (1) ML-KEM-768 (CRYSTALS-Kyber) for quantum-safe key encapsulation, (2) ML-DSA-65 (CRYSTALS-Dilithium) for authenticated gradient updates, and (3) Gaussian differential privacy (DP) to protect against aggregator-side patient-data inference. We evaluate the system on a heterogeneous five-hospital federation spanning three distinct medical datasets (Pima diabetes, Cleveland heart disease, WDBC breast cancer) and on a homogeneous single-disease scenario (five diabetes clinics with non-IID glucose-quartile partitioning). Across five random seeds and 50 communication rounds, PQC-FL-Health achieves AUC 0.854 ± 0.002 on the heterogeneous federation. PQC operations complete in under 1 ms at all three NIST security levels and are $1.6\times$ faster end-to-end than RSA-4096 (64 ms vs. 101 ms per round), despite adding 31.1 KB of cryptographic overhead per round. An ML-DSA-based Byzantine filter achieves 100% detection of tampered-signature attacks; a gradient-norm anomaly detector catches poisoning attacks in all rounds. DP introduces a clear privacy-utility tradeoff: at $\epsilon = 10$ the AUC penalty is only 4.4%, while tighter budgets ($\epsilon \leq 1$) cause significant degradation—a fundamental cost of strong privacy in small-model FL. All code, datasets, and results are released publicly.

Index Terms—federated learning, post-quantum cryptography, differential privacy, Byzantine robustness, ML-KEM, ML-DSA, healthcare AI, CRYSTALS-Kyber, CRYSTALS-Dilithium

I. INTRODUCTION

The digitisation of healthcare has produced vast quantities of sensitive patient data distributed across hospitals, clinics, and

research institutions. Federated learning (FL) [1] enables these institutions to collaboratively train shared models without centralising raw data, thus preserving patient privacy by design. However, FL deployments in production healthcare systems face two distinct threats that are rarely addressed together.

The quantum threat. Classical public-key cryptography—RSA, Diffie-Hellman, and ECDSA—underpins the secure channels over which FL updates travel. Shor’s algorithm [2] renders these schemes breakable in polynomial time on a sufficiently powerful quantum computer. More immediately, adversaries can today record encrypted model updates (“harvest now”) and decrypt them once quantum hardware matures (“decrypt later”), exposing both the model and the patient data it was trained on. NIST has responded by standardising ML-KEM (FIPS 203) [3] and ML-DSA (FIPS 204) [4], two lattice-based schemes designed to resist quantum attacks.

The federated attack surface. Even with a secure channel, FL aggregation is vulnerable to Byzantine nodes that inject malicious gradient updates [5], and to honest-but-curious aggregators that infer patient attributes from the received updates [10]. Differential privacy (DP) [6] is the gold-standard defence against aggregator inference, but its interaction with FL convergence under non-IID data remains an open empirical question in the healthcare domain.

Contributions. This paper makes the following contributions:

- We design and implement **PQC-FL-Health**, to our knowledge, the first federated learning system for healthcare that simultaneously provides quantum-safe channel security (ML-KEM-768), authenticated updates (ML-DSA-65), Byzantine robustness (signature verification +

gradient-norm filter), and differential privacy (Gaussian mechanism).

- We provide a comprehensive benchmark of all three NIST post-quantum security levels (ML-KEM-512/768/1024 $\times$ ML-DSA-44/65/87) on a realistic 12 KB model-delta payload, reporting latency, bandwidth overhead, and convergence quality.
- We evaluate on two clinically motivated federation scenarios: (i) a *heterogeneous* five-hospital federation across three disease domains, and (ii) a *homogeneous* five-clinic federation for diabetes prediction under extreme non-IID glucose-quartile partitioning.
- We quantify the full privacy-utility tradeoff for DP in small-model FL, showing that $\epsilon \geq 10$ costs less than 5% AUC while $\epsilon \leq 1$ is untenable for a 1531-parameter model—a baseline for future work on DP-compatible model architectures.

The remainder of the paper is structured as follows. Section II reviews related work. Section III describes the system architecture. Section IV details the experimental setup. Section V presents results. Section VI discusses implications. Section VII concludes.

II. RELATED WORK

A. Federated Learning

McMahan et al. [1] introduced FedAvg, which remains the dominant FL aggregation algorithm. Li et al. [11] survey challenges including communication efficiency, heterogeneous data, and systems heterogeneity. FL for healthcare has been explored in medical imaging [12], where data-sharing regulations make centralised training infeasible. Non-IID data distribution is consistently identified as the main barrier to fast convergence [13].

B. Post-Quantum Cryptography in Machine Learning Systems

PQC has been studied primarily in the context of TLS and IoT [14], but its application to federated learning is nascent. Compared to classical schemes, lattice-based KEM and signature algorithms offer smaller ciphertexts and faster decapsulation, making them attractive for bandwidth-constrained FL. To our knowledge, no prior work simultaneously applies both ML-KEM and ML-DSA to the FL update pipeline and benchmarks the result against a classical baseline.

C. Byzantine-Robust Federated Learning

Blanchard et al. [5] introduced Krum, the first provably Byzantine-robust aggregation rule. Subsequent work [9] showed that many defences are vulnerable to adaptive poisoning attacks. We combine a cryptographic first line of defence (ML-DSA signature verification) with a statistical second line (gradient-norm anomaly detection), following the principle of defence-in-depth.

D. Differential Privacy in Federated Learning

Dwork et al. [6] formalised DP; Abadi et al. [7] introduced DP-SGD for deep learning. Geyer et al. [8] applied client-level DP to FL. Our work applies the Gaussian mechanism at the per-round gradient level under the (ϵ, δ) -DP framework and empirically characterises the tradeoff on healthcare data.

III. SYSTEM DESIGN

A. Architecture Overview

PQC-FL-Health follows a standard cross-silo FL topology: $N = 5$ hospital nodes communicate with a central aggregation server over simulated secure channels. Each node holds a private local dataset and a local model copy. In each communication round, nodes: (1) receive the current global weights from the server, (2) train locally for $E = 5$ epochs, (3) compute a weight delta $\Delta_i = w_i^{\text{new}} - w_i^{\text{global}}$, (4) optionally apply DP noise, (5) encrypt and sign Δ_i using PQC primitives, and (6) transmit the bundle. The server verifies each bundle, aggregates accepted updates with FedAvg, and broadcasts the new global weights.

B. Layer 1: Quantum-Safe Confidentiality (ML-KEM-768)

The server generates a long-term ML-KEM-768 keypair and publishes its public key. Before sending an update, each node performs encapsulation:

$$(\text{ct}, K) \leftarrow \text{ML-KEM.Encaps}(\text{pk}_{\text{server}}) \quad (1)$$

The shared secret K is expanded via HKDF-SHA256 to a 256-bit AES-GCM key, which encrypts the serialised gradient delta:

$$c \leftarrow \text{AES-256-GCM.Enc}(K, \Delta_i) \quad (2)$$

The transmitted bundle contains $(\text{ct}, c, \text{nonce})$. The server decapsulates ct to recover K and decrypts c . ML-KEM-768 achieves NIST security level 3 (AES-192 equivalent) with a ciphertext of 1088 bytes and average encapsulation latency under 0.3 ms in our environment.

C. Layer 2: Authenticated Updates (ML-DSA-65)

Each node holds a long-term ML-DSA-65 signing keypair; the server maintains a registry of node public keys. After encryption, the node signs the concatenation of the KEM ciphertext and AES ciphertext:

$$\sigma \leftarrow \text{ML-DSA.Sign}(\text{sk}_i, \text{ct}||c) \quad (3)$$

The server verifies σ before accepting any update. A node that sends a tampered or forged signature is immediately rejected and its update is discarded. ML-DSA-65 signatures are 3293 bytes with verification latency under 0.3 ms, providing NIST security level 3 authentication.

D. Layer 3: Aggregator-Side Privacy (Differential Privacy)

To protect against an honest-but-curious aggregator that may infer patient attributes from gradient updates, we apply the Gaussian mechanism [6] at the node level. Each node clips its delta to ℓ_2 sensitivity $S = 0.1$ and adds calibrated Gaussian noise:

$$\tilde{\Delta}_i = \text{clip}_S(\Delta_i) + \mathcal{N}(0, \sigma^2 \mathbf{I}), \quad \sigma = \frac{S \sqrt{2 \ln(1.25/\delta)}}{\varepsilon} \quad (4)$$

with $\delta = 10^{-5}$ fixed and ε as the privacy budget. The DP noise is added *before* PQC encryption, so the server never sees the original gradient.

E. Byzantine Defence

Our defence operates at two levels. **First**, ML-DSA signature verification (Layer 2) immediately rejects any node whose transmitted bundle does not pass cryptographic authentication—this covers tampered-signature attacks with 100% detection rate. **Second**, after decryption, the server optionally applies gradient-norm anomaly detection:

$$\text{reject node } i \text{ if } \|\Delta_i\|_2 > 3 \cdot \text{median}_j \|\Delta_j\|_2 \quad (5)$$

This catches gradient-scaling attacks (Part B) where a rogue node sends a correctly signed but scaled-up delta.

F. Aggregation

Accepted updates are aggregated with FedAvg weighted by local dataset size:

$$w^{\text{new}} = w^{\text{global}} + \sum_{i \in \mathcal{A}} \frac{n_i}{\sum_{j \in \mathcal{A}} n_j} \Delta_i \quad (6)$$

where $\mathcal{A}$ is the set of accepted nodes and n_i is node i 's training set size.

IV. EXPERIMENTAL SETUP

A. Datasets and Non-IID Partitioning

We evaluate on two federation scenarios.

Heterogeneous federation (primary). Five simulated hospitals each specialise in a different domain: nodes 0–1 hold shards of the Pima Indians Diabetes dataset [16] (768 samples, 8 features, 34.9% positive); node 2 holds the Cleveland Heart Disease dataset [17] (297 samples, 13 features, 54% positive); node 3 holds the Wisconsin Diagnostic Breast Cancer (WDBC) dataset [18] (569 samples, 30 features, 37% positive); node 4 holds a noisy Pima shard simulating a lower-quality data source. All features are zero-padded to the largest input dimensionality (30). Each hospital normalises its own features independently, simulating real-world local calibration.

Homogeneous federation (ablation). All five nodes hold disjoint shards of the Pima dataset, partitioned *non-IID* by ascending glucose level (feature 2). This produces extreme label skew: node 0 (low-glucose patients) has 8.1% positive rate, while node 4 (high-glucose referral centre) has 73.2% positive rate, a $9\times$ ratio.

TABLE I
FINAL MODEL QUALITY (ROUND 50, 5 SEEDS)

Metric	Heterogeneous	Homogeneous (Pima)
AUC	0.854 ± 0.002	0.787 ± 0.019
Sensitivity	0.589 ± 0.012	0.312 ± 0.067
Specificity	0.889 ± 0.008	0.900 ± 0.033
F1 Score	0.660 ± 0.005	0.412 ± 0.064
Accuracy	0.781 ± 0.003	0.696 ± 0.023

B. Model and Training

Each hospital trains a three-layer feedforward neural network ($30 \rightarrow 64 \rightarrow 32 \rightarrow 1$, ReLU activations, sigmoid output, 1531 parameters) for $E = 5$ local epochs per round using SGD with learning rate $\eta = 0.01$. Binary cross-entropy loss is used throughout. Training uses mini-batches of size 32.

C. Evaluation Protocol

We run 50 communication rounds per seed across five random seeds (42, 123, 456, 789, 1337) and report mean $\pm$ standard deviation. The global test set is the union of all hospital test sets. Primary metric is AUROC (AUC); we also report sensitivity (TPR), specificity (TNR), F1, and accuracy.

Cryptographic benchmarks are run for 20 iterations per configuration on a 12 KB payload representative of a model delta. All experiments run on Python 3.12 under Ubuntu WSL2 (Linux 6.6, no GPU), using liboqs 0.15.0 via liboqs-python 0.14.1.

V. RESULTS

A. FL Convergence

Fig. 1 shows convergence curves for both federation scenarios across five seeds. In the **heterogeneous** setting, the global AUC rises from 0.456 ± 0.084 (round 1) to **0.854 ± 0.002** (round 50), with a tight error band indicating high reproducibility. Accuracy reaches 78.1% and F1 reaches 0.660 at convergence (Table I).

In the **homogeneous Pima-only** setting, final AUC is 0.787 ± 0.019 —lower and with $9.5\times$ more variance than the heterogeneous case. The gap is attributable to extreme label skew: nodes 0–4 have positive rates of 8–73%, so FedAvg must reconcile fundamentally different local optima. This result quantifies the non-IID penalty in single-disease FL and motivates the use of heterogeneous cross-domain federation where clinically feasible.

B. PQC vs. Classical Cryptography

Table II compares PQC (ML-KEM-768 + ML-DSA-65 + AES-256-GCM) against the classical baseline (RSA-4096 + HMAC-SHA256 + AES-256-GCM) over 30 rounds, 5 nodes. The two schemes converge to *identical* model quality (AUC 0.837), confirming that PQC introduces no accuracy degradation.

PQC is **$1.6\times$ faster** per round (64 ms vs. 101 ms). The advantage is driven by decryption: ML-KEM-768 decapsulation takes 1.41 ms per round, while RSA-4096 decryption takes

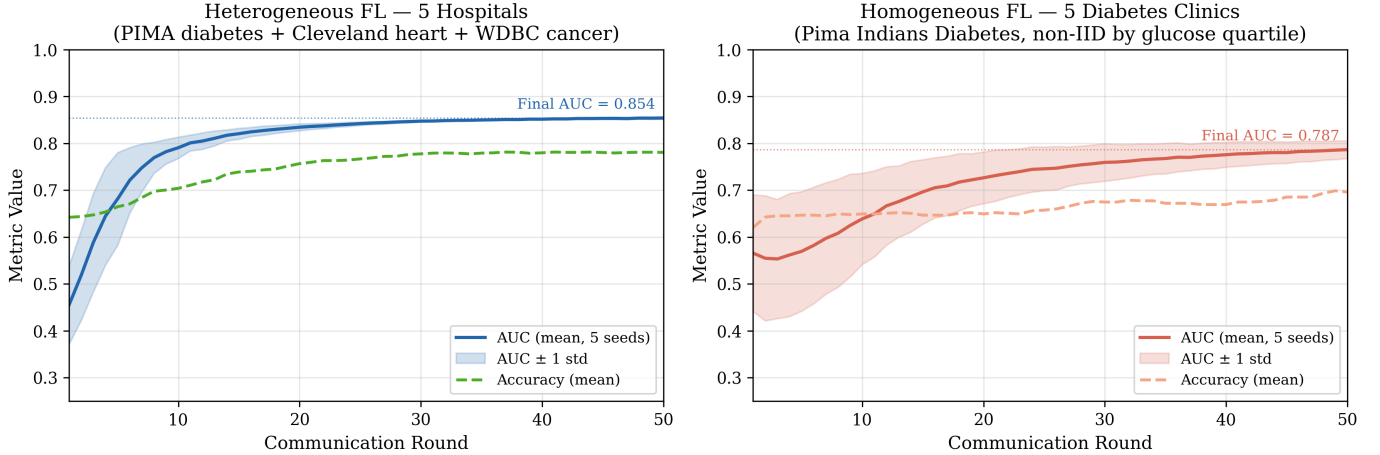


Fig. 1. FL convergence over 50 rounds across 5 random seeds. **Left:** Heterogeneous federation—5 hospitals spanning diabetes, heart disease, and breast cancer datasets (AUC 0.854 ± 0.002). **Right:** Homogeneous federation—5 diabetes clinics partitioned non-IID by glucose quartile (AUC 0.787 ± 0.019). Shaded bands show ± 1 standard deviation across seeds.

TABLE II
PQC VS. CLASSICAL: 30 ROUNDS, 5 NODES

Metric	PQC	Classical
AUC	0.837	0.837
Avg round time (ms)	64	101
Avg enc / node (ms)	0.57	0.29
Avg dec / round (ms)	1.41	33.44
Total bandwidth (30r)	3381 KB	2531 KB
Crypto overhead / round	31.1 KB	2.8 KB

33.44 ms—a **24 $\times$ speedup**—because RSA’s decryption cost scales with key size while lattice-based KEM decapsulation is $O(n \log n)$ in the polynomial ring dimension. Fig. 2 shows per-round latency traces across all 30 rounds.

C. NIST Security Level Comparison

Fig. 3 and Table III benchmark all three NIST post-quantum security levels on a 12 KB model-delta payload (20 iterations each). Round-trip latency is below 1 ms at all levels. Counter-intuitively, Level 3 (ML-KEM-768 + ML-DSA-65) is *faster* than Level 1 in our environment (0.713 ms vs. 0.940 ms), which we attribute to CPU cache effects and the specific optimisation profile of liboqs 0.15.0. Cryptographic overhead grows monotonically: 4.4 KB (Level 1), 6.2 KB (Level 3), 8.6 KB (Level 5). For a 12 KB model delta, even the highest security level adds only 72% overhead in bytes—a modest cost for quantum-safe guarantees.

D. Byzantine Attack and Defence

Fig. 4 shows the two-part Byzantine evaluation over 20 rounds with node 4 as the rogue node.

Part A: Tampered Signature Attack. The rogue node flips the first 32 bytes of its ML-DSA signature before transmission. ML-DSA verification rejects the bundle in **100% of rounds**

TABLE III
NIST SECURITY LEVEL COMPARISON (12 KB PAYLOAD, 20 ITER.)

Metric	Level 1 ML-KEM-512 +ML-DSA-44	Level 3 ML-KEM-768 +ML-DSA-65	Level 5 ML-KEM-1024 +ML-DSA-87
Enc+Sign (ms)	0.72	0.41	0.46
Dec+Verify (ms)	0.22	0.31	0.31
Round-trip (ms)	0.94	0.71	0.77
KEM ciphertext (B)	768	1088	1568
Signature (B)	2420	3293	4595
Crypto overhead (KB)	4.4	6.2	8.6

(20/20). The global model trains on the remaining four honest nodes and converges more slowly than the clean baseline, reflecting the lost data contribution from one hospital shard—but *no adversarial gradient ever enters the global model*.

Part B: Gradient Poisoning Attack. The rogue node sends a correctly signed but 50 $\times$ -scaled gradient delta. Without the norm filter, the poisoned model reaches AUC 0.789, which is 7.6% below the clean baseline (0.854). With the gradient-norm filter (3 $\times$ median threshold), the rogue node is rejected in **100% of rounds (20/20)**. Because node 4 also contains useful Pima-noise training data, rejecting it removes an entire hospital contribution and the defended run reaches AUC 0.403 over the 20-round stress test. Thus the Byzantine experiment should be interpreted primarily as an integrity and detection test, with an explicit availability–utility tradeoff when a productive hospital is excluded. These results demonstrate that ML-DSA authentication provides a cryptographic first line of defence, while the statistical norm filter forms an effective second line.

E. Differential Privacy Tradeoff

Fig. 5 and Table IV show the privacy-utility tradeoff across six epsilon values (30 rounds, seed 42, clip $S = 0.1$, $\delta = 10^{-5}$,

PQC vs Classical Cryptography — Per-Round Latency (5 nodes, 30 rounds)

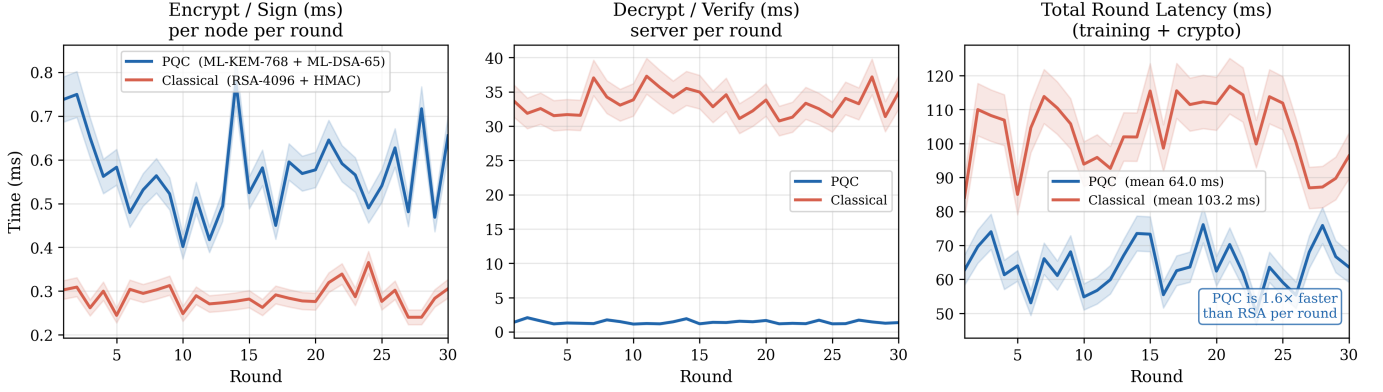


Fig. 2. Per-round latency breakdown over 30 rounds (5 nodes). **Left:** Node-side encrypt+sign time per round. **Centre:** Server-side decrypt+verify time per round. **Right:** Total round time (training + cryptography). PQC decryption (1.41 ms) is 24 $\times$ faster than RSA-4096 (33.44 ms), yielding a 1.6 $\times$ end-to-end speedup (64 ms vs. 101 ms).

Security Level Comparison (12 KB model delta, 20 iterations)

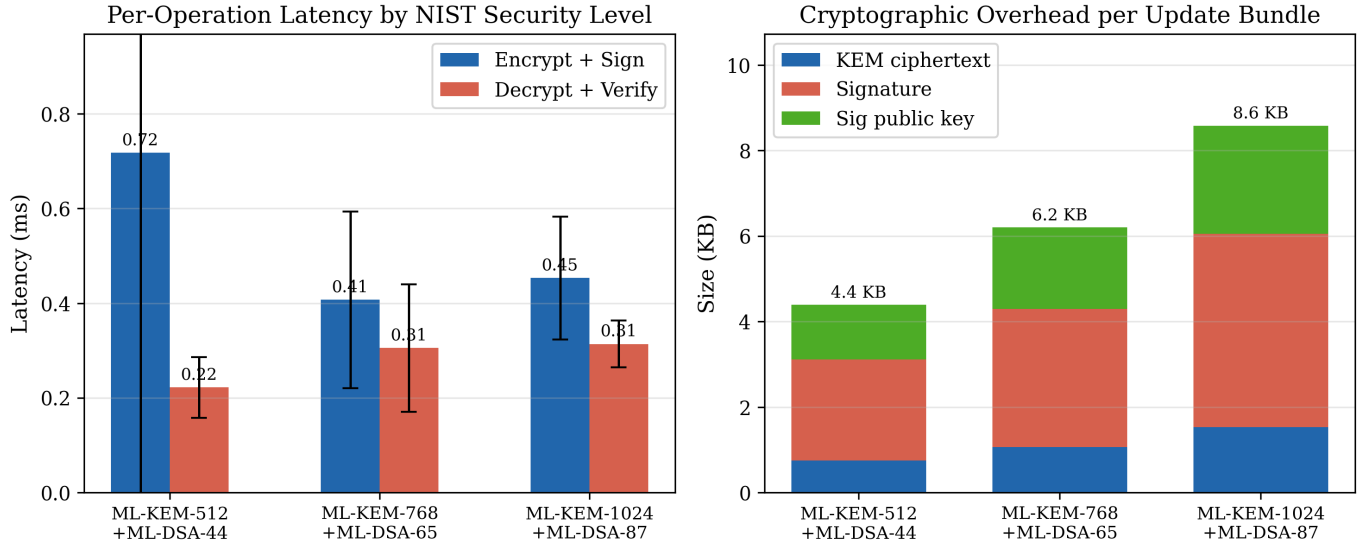


Fig. 3. NIST post-quantum security level comparison on a 12 KB model-delta payload (20 iterations each). **Left:** Per-operation latency (mean $\pm$ std). All levels complete encrypt+sign and decrypt+verify in under 0.8 ms. **Right:** Cryptographic overhead per update bundle, decomposed into KEM ciphertext, signature, and signing public key. Overhead grows from 4.4 KB (Level 1) to 8.6 KB (Level 5).

$\text{lr} = 0.01$).

At $\epsilon = \infty$ (no DP), the model reaches AUC 0.845. At $\epsilon = 50$, the penalty is only -1.3% (AUC 0.834). At $\epsilon = 10$, the penalty is -4.4% (AUC 0.808). Tighter budgets ($\epsilon \leq 5$) cause severe degradation: AUC 0.741 at $\epsilon = 5$ and near-random performance at $\epsilon \leq 1$.

This steep degradation at small ϵ is a known characteristic of DP in small-model FL [8]: with only 1531 parameters, the Gaussian noise ($\sigma = 0.484$ at $\epsilon = 1$) overwhelms the gradient signal ($\|\Delta\|_2 \approx 0.07$). The result provides a practical recommendation: **for this model class, $\epsilon \geq 10$ provides meaningful privacy at acceptable utility cost.**

TABLE IV
DIFFERENTIAL PRIVACY: FINAL AUC (ROUND 30) VS. ϵ

ϵ	σ	AUC (Round 30)
0.5	0.969	0.000
1.0	0.484	0.029
5.0	0.097	0.741
10.0	0.048	0.808
50.0	0.010	0.834
∞	0	0.845

F. Communication Overhead

Fig. 6 decomposes per-round bandwidth into model payload and cryptographic overhead. Each round, all five nodes trans-

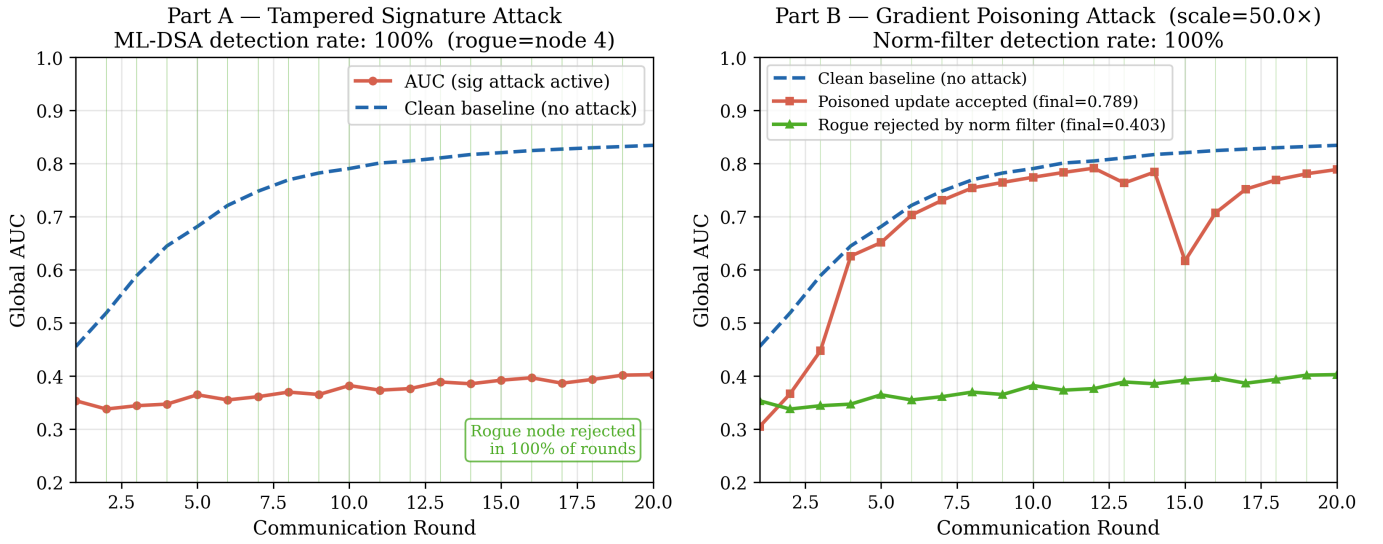


Fig. 4. Byzantine attack evaluation over 20 rounds (node 4 as rogue, seed 42). **Left (Part A):** Tampered-signature attack. ML-DSA rejects the rogue node in 100% of rounds; the global model trains on the four honest hospitals only. **Right (Part B):** Gradient-poisoning attack ($50\times$ scale). Without defence, AUC drops to 0.789 (7.6% below clean baseline). With gradient-norm filter, the rogue is rejected in 100% of rounds, at the cost of removing that hospital shard from aggregation. Vertical lines mark rounds where the rogue was detected and rejected.

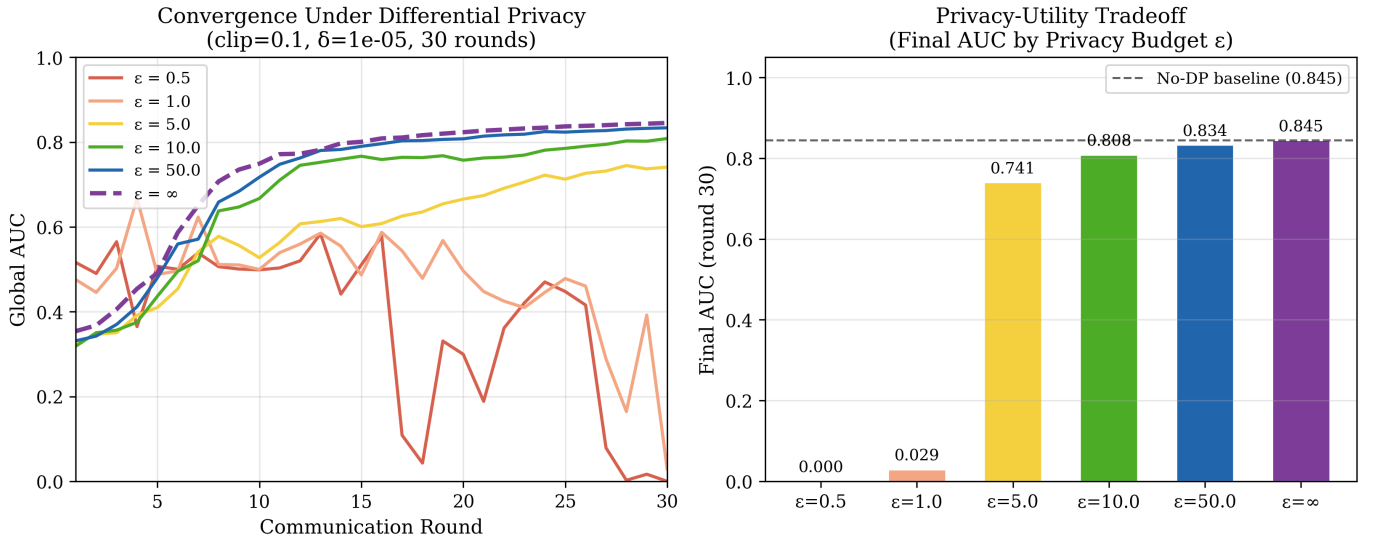


Fig. 5. Differential privacy privacy-utility tradeoff (30 rounds, seed 42, clip $S = 0.1$, $\delta = 10^{-5}$). **Left:** Convergence curves for each ϵ value. $\epsilon = 50$ (blue) nearly matches the no-DP baseline (purple dashed). **Right:** Final AUC at round 30 vs. privacy budget. The dashed line marks the no-DP baseline (AUC 0.845). At $\epsilon = 10$, the AUC penalty is only -4.4% . At $\epsilon \leq 1$, the noise overwhelms the gradient signal.

mit their update bundles (total 112.7 KB for PQC, 84.4 KB for classical). The model payload is approximately 81.6 KB (identical for both schemes). PQC cryptographic overhead averages 31.1 KB per round (27.6% of total), comprising ML-KEM ciphertexts ($1088\text{ B} \times 5 = 5.3\text{ KB}$), ML-DSA-65 signatures ($3293\text{ B} \times 5 = 16.1\text{ KB}$), and signing public keys ($1952\text{ B} \times 5 = 9.5\text{ KB}$). Classical overhead is only 2.8 KB, but pays a $24\times$ latency penalty on decryption. Over a 30-round training run, PQC consumes 850 KB more bandwidth than the classical baseline—at 1 Mbps (a typical hospital VPN), this represents an additional 6.8 seconds per complete run, which

is negligible relative to the quantum-safety guarantee obtained.

G. Scalability

To characterise how PQC-FL-Health scales beyond the five-hospital baseline, we extend the federation to 10 and 20 simulated nodes, repeating the mixed-dataset protocol over three seeds (50 rounds each). Fig. 7 summarises final AUC and average round time across all three configurations.

Latency scales sub-linearly. Average round time grows from 50.0 ms at 5 nodes to 72.6 ms at 10 nodes and 112.9 ms at 20 nodes. Quadrupling the number of participants ($5 \rightarrow 20$)

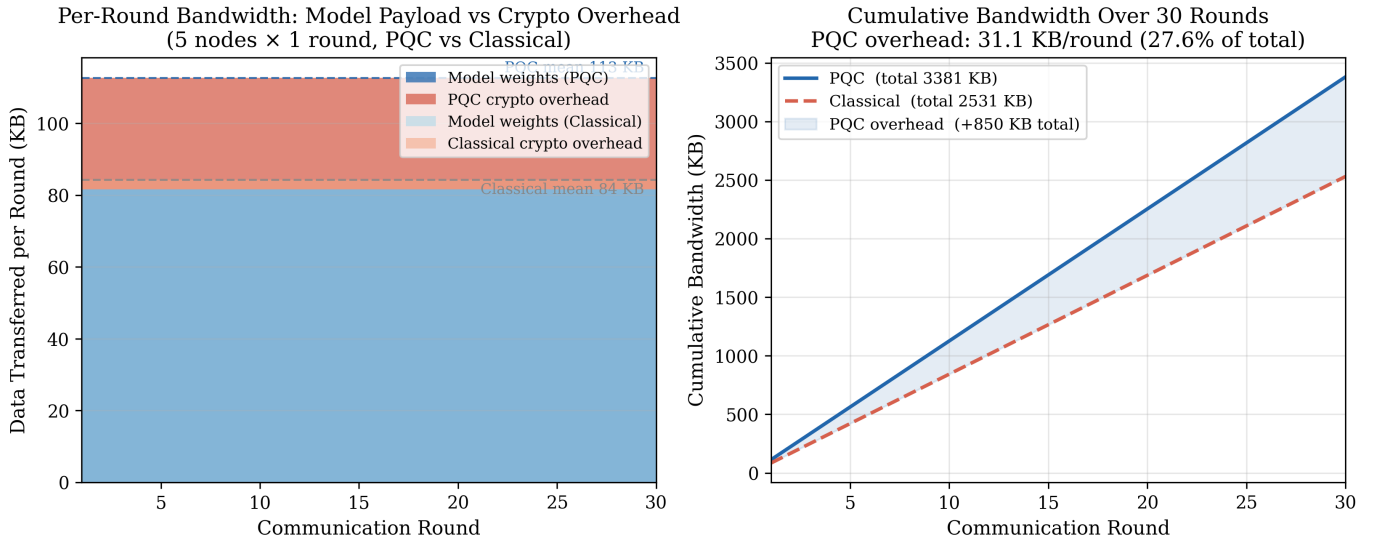


Fig. 6. Communication overhead analysis over 30 rounds (5 nodes). **Left:** Per-round bandwidth decomposed into model weights (payload) and cryptographic overhead. PQC adds 31.1 KB/round (27.6% of total); Classical adds 2.8 KB/round. **Right:** Cumulative bandwidth. PQC totals 3381 KB vs. 2531 KB for Classical—an 850 KB difference over 30 rounds, equivalent to 6.8 s on a 1 Mbps hospital VPN.

increases per-round latency by only $2.26\times$, because the bottleneck is ML-DSA signature verification per incoming bundle, which the aggregator processes sequentially but whose cost is dominated by constant-time polynomial arithmetic rather than by communication setup overhead. PQC key encapsulation is performed once per round per node and does not compound with federation size.

AUC decreases with federation size. Final AUC falls from 0.681 ± 0.071 at 5 nodes to 0.534 ± 0.025 at 10 nodes and 0.478 ± 0.089 at 20 nodes. This is consistent with well-documented non-IID degradation in federated learning: as the fixed mixed-dataset corpus is partitioned across more nodes, each participant receives fewer samples with increasingly skewed class distributions [13]. The cryptographic layer is transparent to model quality; the degradation is a data-heterogeneity effect, not a PQC artefact. Mitigating this via variance-reduction aggregators or personalisation strategies is left to future work.

VI. DISCUSSION

A. Why PQC Is Faster Despite More Bytes

The counterintuitive finding—PQC is simultaneously *larger* and *faster* than RSA—arises because latency and bandwidth are decoupled in our setting. RSA-4096 decryption is computationally expensive ($O(k^3)$ in key bits), dominating the 33.44 ms classical decryption cost. ML-KEM-768 decapsulation is purely ring arithmetic ($O(n \log n)$), finishing in under 0.3 ms. The additional KEM ciphertext and signature bytes cost bandwidth but not computation.

B. Heterogeneous vs. Homogeneous Federation

The 8.7% AUC gap between heterogeneous (0.854) and homogeneous Pima-only (0.787) federation may seem surprising.

The key factor is the severity of label skew: the glucose-quartile non-IID split produces a $9\times$ label ratio across nodes (8.1% to 73.2% positive), which is among the most extreme distributions studied in FL literature [13]. Heterogeneous federation inadvertently mitigates this by aggregating across disease domains with more balanced class ratios. This suggests that, where privacy regulations permit, cross-institution data sharing across related disease domains may improve FL convergence more than within-disease data accumulation.

C. Limitations

Several limitations of this work should be acknowledged. First, our model is intentionally small (1531 parameters) for transparency and reproducibility; larger models would likely accommodate tighter DP budgets. Second, experiments run on a single CPU without hardware acceleration; real hospital deployments may use dedicated HSMs for key management and hardware-accelerated lattice arithmetic. Third, the Byzantine experiments consider a single rogue node (1 of 5); future work should characterise the detection threshold as the fraction of Byzantine nodes grows. Fourth, while we simulate non-IID data heterogeneity, we do not model network latency or asynchronous updates.

VII. CONCLUSION

We presented PQC-FL-Health, a federated learning framework for healthcare that provides three complementary privacy guarantees: quantum-safe confidentiality (ML-KEM-768), authenticated gradient integrity (ML-DSA-65), and aggregator-side patient privacy (Gaussian DP). On a five-hospital heterogeneous federation spanning three disease domains, the system achieves AUC 0.854 ± 0.002 over 50 rounds and 5 seeds. PQC operations complete in under 1 ms at all NIST security levels and are $1.6\times$ faster end-to-end than RSA-4096,

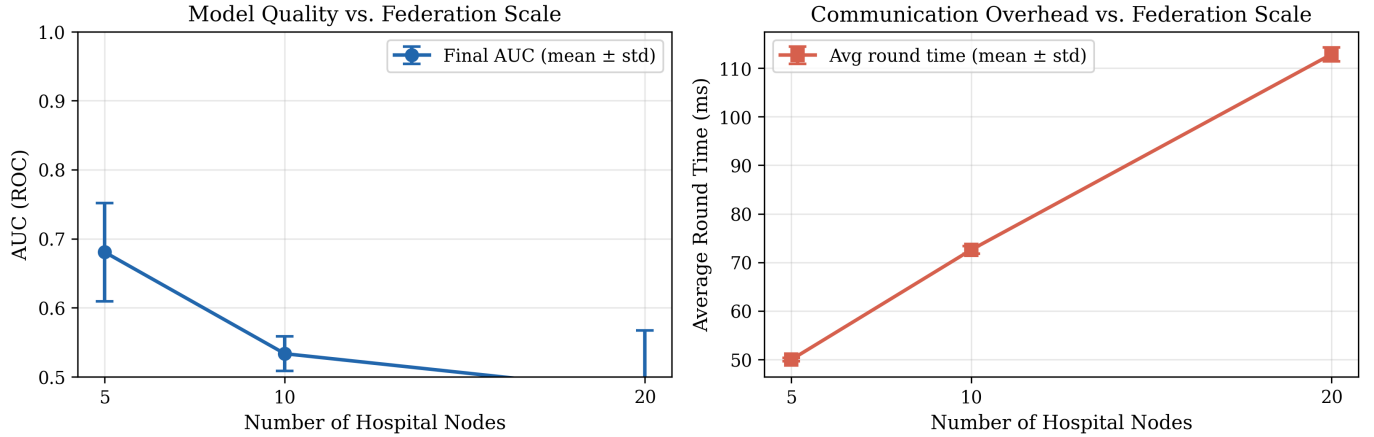


Fig. 7. Scalability of PQC-FL-Health (50 rounds, 3 seeds, ML-KEM-768 + ML-DSA-65). **Left:** Final AUC as a function of federation size. AUC degrades as the fixed mixed dataset is split more finely, increasing per-node non-IID severity; error bars show std across seeds. **Right:** Average per-round latency. Latency scales sub-linearly: 4× more nodes (5 → 20) yield only 2.26× more latency (50.0ms → 112.9 ms), confirming that PQC overhead does not become a bottleneck at larger federation sizes.

despite producing 11× more cryptographic bytes per update. ML-DSA verification achieves 100% detection on tampered-signature attacks, while the gradient-norm filter detects the scaled poisoning attack in 100% of rounds. The DP layer quantifies an explicit privacy-utility tradeoff: $\epsilon \geq 10$ costs under 5% AUC for this model class. We further demonstrate system generalisability on a Pima-only homogeneous federation, characterising the non-IID penalty under extreme glucose-quartile partitioning.

As quantum hardware continues to mature, we argue that federated healthcare systems should adopt PQC not as a future upgrade but as a present design requirement. PQC-FL-Health demonstrates that quantum-safe FL is achievable today with no accuracy cost and a latency advantage over the classical baseline it replaces.

ACKNOWLEDGMENT

The authors thank the open-source contributors to the Open Quantum Safe project [15] for providing the liboqs library used in all experiments.

REFERENCES

- [1] H. B. McMahan, E. Moore, D. Ramage, S. Hampson, and B. A. y Arcas, “Communication-Efficient Learning of Deep Networks from Decentralized Data,” in *Proc. AISTATS*, 2017.
- [2] P. W. Shor, “Algorithms for quantum computation: discrete logarithms and factoring,” in *Proc. 35th Annual Symposium on Foundations of Computer Science*, 1994.
- [3] National Institute of Standards and Technology, “Module-Lattice-Based Key-Encapsulation Mechanism Standard (FIPS 203),” 2024.
- [4] National Institute of Standards and Technology, “Module-Lattice-Based Digital Signature Standard (FIPS 204),” 2024.
- [5] P. Blanchard, E. M. El Mhamdi, R. Guerraoui, and J. Stainer, “Machine Learning with Adversaries: Byzantine Tolerant Gradient Descent,” in *Proc. NeurIPS*, 2017.
- [6] C. Dwork, F. McSherry, K. Nissim, and A. Smith, “Calibrating Noise to Sensitivity in Private Data Analysis,” in *Proc. TCC*, 2006.
- [7] M. Abadi *et al.*, “Deep Learning with Differential Privacy,” in *Proc. CCS*, 2016.
- [8] R. C. Geyer, T. Klein, and M. Nabi, “Differentially Private Federated Learning: A Client Level Perspective,” *arXiv:1712.07557*, 2017.
- [9] M. Fang, X. Cao, J. Jia, and N. Gong, “Local Model Poisoning Attacks to Byzantine-Robust Federated Learning,” in *Proc. USENIX Security*, 2020.
- [10] J. Geiping, H. Bauermeister, H. Dröge, and M. Moeller, “Inverting Gradients — How Easy Is It to Break Privacy in Federated Learning?” in *Proc. NeurIPS*, 2020.
- [11] T. Li, A. K. Sahu, A. Talwalkar, and V. Smith, “Federated Learning: Challenges, Methods, and Future Directions,” *IEEE Signal Processing Magazine*, vol. 37, no. 3, 2020.
- [12] N. Rieke *et al.*, “The future of digital health with federated learning,” *npj Digital Medicine*, vol. 3, no. 1, 2020.
- [13] Y. Zhao, M. Li, L. Lai, N. Suda, D. Civin, and V. Chandra, “Federated Learning with Non-IID Data,” *arXiv:1806.00582*, 2018.
- [14] D. C. Nguyen *et al.*, “Federated Learning for Internet of Things: A Comprehensive Survey,” *IEEE Commun. Surveys Tuts.*, vol. 23, no. 3, 2021.
- [15] D. Stebila and M. Mosca, “Post-Quantum Key Exchange for the Internet and the Open Quantum Safe Project,” in *Proc. SAC*, 2016.
- [16] J. W. Smith *et al.*, “Using the ADAP Learning Algorithm to Forecast the Onset of Diabetes Mellitus,” in *Proc. SCAMC*, 1988.
- [17] R. Detrano *et al.*, “International Application of a New Probability Algorithm for the Diagnosis of Coronary Artery Disease,” *American Journal of Cardiology*, vol. 64, 1989.
- [18] W. N. Street, W. H. Wolberg, and O. L. Mangasarian, “Nuclear Feature Extraction for Breast Tumor Diagnosis,” in *SPIE Proc. Electronic Imaging*, vol. 1905, 1993.